INSTITUT PUIG CASTELLAR

A4.3. Pràctica: Certificats digitals X.509 amb OpenSSL

0226. Seguretat informàtica	GRUP: SMX2_
RA4. Assegura la privadesa de la informació transmesa en xarxes informàtiques descrivint vulnerabilitats i instal·lant programari específic.	
NOM I COGNOMS: Posa el teu nom i cognoms.	**DATA:** Escriu la data.

Enunciat de l'activitat:

Aquesta activitat es cenyeix a l'apartat NF5-AA3 (Signatura digital) del RA4: signatura digital vs. electrònica, certificats X.509, autoritats de certificació (CA) i els tres nivells legals de signatura electrònica (eIDAS).

Identificació de les captures. Abans de començar qualsevol pas amb el terminal d'Ubuntu, canvia el nom de l'equip pel teu nom i cognom, perquè quedi clar que les captures les has fet tu:

1) Executa sudo hostname nom-cognom, amb el teu nom i primer cognom en minúscules, sense accents ni espais (p. ex. sudo hostname joan-sanchez).

2) Tanca el terminal i obre'n un de nou: l'indicador i la barra superior de la finestra mostraran el nom nou (p. ex. usuario@joan-sanchez).

El canvi és temporal: si la màquina virtual es tanca, es reinicia o s'apaga, es perd, i a la sessió següent cal tornar a executar sudo hostname nom-cognom. Totes les captures de terminal que lliuris han de mostrar aquest nom; les que no el mostrin no es consideraran vàlides.

Part 1 · Generació d'un certificat X.509 autosignat

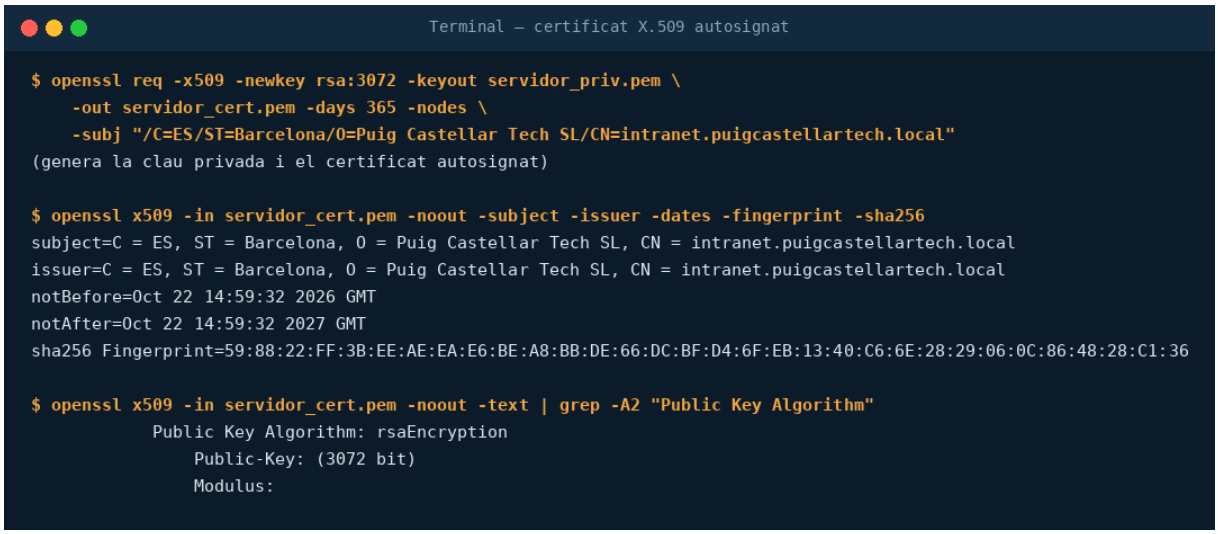
Pas 1. Genera, en una sola ordre, una clau privada RSA i un certificat X.509 autosignat per a un servidor intern (per exemple, la intranet d'una empresa fictícia):

```
$ openssl req -x509 -newkey rsa:3072 \
    -keyout servidor_priv.pem -out servidor_cert.pem \
    -days 365 -nodes \
    -subj "/C=ES/ST=Barcelona/O=Puig Castellar Tech
SL/CN=intranet.puigcastellartech.local"
```

Pas 2. Inspecciona el certificat generat: subjecte, emissor, dates de validesa i empremta digital (fingerprint):

```
$ openssl x509 -in servidor_cert.pem -noout \
    -subject -issuer -dates -fingerprint -sha256
```

Part 1 · Generació d'un certificat X.509 autosignat



Captura real: generació d'una clau RSA de 3072 bits i un certificat X.509 autosignat, i inspecció de les seves dades principals (subjecte, emissor, validesa i empremta SHA-256).

Reprodueix aquest experiment amb les teves pròpies dades (per exemple, amb el nom d'una empresa fictícia) [CAPTURA] i respon:

a) Compara els camps "subject=" i "issuer=" del teu certificat: què hi observes, i què vol dir que coincideixin?

b) És aquest certificat vàlid per a un lloc web PÚBLIC d'Internet (per exemple, la botiga en línia d'una empresa real)? Per què?

c) Per a quin tipus d'ús SÍ seria adequat un certificat autosignat com aquest?

Part 2 · Del certificat autosignat a un certificat "de veritat"

Respon, relacionant-ho amb la teoria:

a) Si volguessis que el certificat de la Part 1 fos reconegut automàticament per qualsevol navegador, sense mostrar cap avís de "connexió no segura", quins passos hauries de seguir (relaciona-ho amb el concepte de CA i de model jeràrquic Root CA → CA Intermèdia)?

b) Investiga un proveïdor real de certificats gratuïts per a llocs web (per exemple, Let's Encrypt) i explica breument com verifica la identitat del sol·licitant abans d'emetre el certificat (rol de la RA).

Part 3 · Signatura electrònica: quin nivell necessito?

Per a cadascun dels següents casos, indica quin dels tres nivells d'eIDAS (simple, avançada o qualificada) recomanaries, i justifica la resposta amb un argument tècnic o legal:

a) Acceptar les condicions d'ús d'una aplicació mòbil de música.

b) Signar un contracte de lloguer d'un pis des del mòbil, rebent un codi SMS de verificació.

c) Presentar la declaració de la renda a l'Agència Tributària.

d) Signar internament un document intern de l'empresa que no té cap valor legal fora de l'organització.

Cas pràctic final

Una assessoria fiscal vol començar a signar digitalment els informes que envia als seus 200 clients, per garantir-los que el document no ha estat alterat i que prové realment de l'assessoria. Elabora un informe tècnic que reculli:

1) quin tipus de certificat (autosignat o emès per una CA reconeguda) recomanaries, i per què, tenint en compte que els documents han de ser vàlids fora de l'organització;

2) quin nivell de signatura electrònica (eIDAS) seria l'adequat per a aquest ús;

3) quines mesures prendries per protegir la clau privada de l'assessoria (relaciona-ho amb el que vau veure sobre atacs a la identitat);

4) com explicaries a un client, sense tecnicismes, que la signatura digital li garanteix que el document no ha estat modificat.

Fonts: Repositori "Materials" (GitHub, SMX-0226SI), NF5/AA3-SignaturaDigital.md (CC-BY-SA-4.0); Reglament eIDAS (UE) 910/2014; Signicat, "Electronic signature: what is it and how to use it"; OpenSSL (openssl.org).